Corrigé

Préparation, résultats attendus et corrections du cahier de TP. **Document pensé pour l'enseignant** : si vous suivez ce parcours en autonomie, essayez d'abord de répondre seul(e), puis comparez.

> **Conseil**
> Comparer votre travail à la correction n'a de valeur qu'après avoir tenté le test ou la question. Notez d'abord ce que vous attendez, puis vérifiez.

1. Préparation avant la première séance

Check-list de préparation

- [ ] Hôte Proxmox VE installé et à jour, bridges vmbr1 à vmbr4 créés (ou laissés aux étudiants au TP0)
- [ ] ISO téléversées : Debian netinst, pfSense CE (ou OPNsense), Kali Linux. Gabarits 900 et 901 préparés à l'avance si le temps est compté
- [ ] Un compte Proxmox par groupe avec des droits limités à son pool de VM
- [ ] Plages d'identifiants VM réservées par groupe (100–199, 200–299…) et bridges propres à chaque groupe (vmbr11, vmbr21…) si l'hôte est partagé
- [ ] Mot de passe de la base (TP1) et adresses des cibles communiqués oralement ; rappel du cadre légal avant tout usage de Kali

Organisation conseillée

- Groupes de 2 étudiants, un laboratoire par groupe. Charge approximative : 6 à 8 vCPU, 12 à 16 Go de RAM (Kali : une seule VM en configuration minimale).
- Faire valider le TP2 (pare-feu) par l'enseignant avant le TP3 : une erreur de routage entre les deux pare-feu fausse tous les tests suivants.
- Imposer un snapshot à la fin de chaque TP.
- Variante OPNsense : mêmes principes, menus différents (Firewall > Rules, Firewall > NAT > Port Forward, alias dans Firewall > Aliases). Désactiver le blocage des réseaux privés sur le WAN.
- Variante sans pfSense : deux VM Linux routeurs avec nftables, pour les groupes à l'aise en ligne de commande (plus long).

Variante : laboratoire sur le poste de chaque étudiant

- Vérifier les PC : x86 avec VT-x ou AMD-V activé, 16 Go de RAM, 120 Go libres (Mac Apple exclus) ;
- Hyperviseur commun à la classe (VMware Workstation ou Hyper-V), conditions de licence confirmées ;
- Anticiper le conflit Hyper-V / WSL2 / intégrité de la mémoire sous Windows ;
- Distribuer une VM Proxmox préconfigurée (OVA) avec bridges, gabarits et conteneur WEB-EXT pour gagner le TP0 ;
- Imposer le profil léger sur les PC de 16 Go ; prévoir un poste de secours ;
- Compter 30 à 50 % de lenteur : 15 à 20 minutes de plus pour le TP2. Les résultats attendus de la recette sont identiques.

2. Fiche de recette (TP6) : résultats attendus

Test	Résultat attendu	Interprétation
T1	Seuls 80/tcp et 443/tcp sont open, les 65 533 autres ports sont filtered	Seules les redirections NAT sont visibles ; surface d'attaque minimale
T2	80 et 443 ouverts, service Nginx identifié (version masquée après le TP7)	Le reverse-proxy est la seule vitrine
T3	HTTP 200 (réponse de SRV-APP relayée par le proxy)	Flux Internet vers application via DMZ fonctionnel
T4	Tous les ports filtered (ou hôte injoignable)	Le réseau interne est invisible depuis Internet
T5	Sur 192.168.20.20 : 8080 open, 22 et 80 filtered ; sur 192.168.20.30 : tout filtered	Un poste utilisateur n'atteint que l'application, jamais la base
T6	Délai d'attente dépassé (blocage)	L'interface d'administration du pare-feu n'est pas accessible aux utilisateurs
T7	HTTP 200	Flux utilisateur vers application autorisé
T8	HTTP 200	Sortie vers « Internet » simulé, via le NAT de FW-EXT
T9	Blocage (curl code 28, délai dépassé)	Les invités n'atteignent pas les serveurs
T10	HTTP 200	Les invités ont un accès Internet seul

T11	Connexion réussie (open)	Seul flux DMZ vers interne autorisé
T12	Blocage	RP-DMZ compromis ne peut pas atteindre la base
T13	Blocage	RP-DMZ compromis ne peut pas rebondir vers les postes
T14	Connexion réussie (après TP7 : par clé uniquement)	L'administration passe par le poste du VLAN 30
T15	Blocage	Un poste utilisateur ne peut pas administrer les serveurs

3. Matrice de flux (TP5) : correction

N°	Flux	Décision	Justification attendue
1	Internet vers RP-DMZ, TCP 80/443	A	Service public ; le 80 sert à rediriger vers le 443
2	Internet vers réseau interne	R	Aucun accès direct à l'interne depuis une zone non fiable
3	RP-DMZ vers SRV-APP, TCP 8080	A	Unique flux DMZ vers interne, une source, une destination, un port
4	RP-DMZ vers SRV-BDD, TCP 3306	R	Le proxy n'a aucun besoin de la base ; c'est l'application qui l'interroge
5	DMZ vers VLAN Utilisateurs	R	Empêcher le rebond depuis une zone exposée
6	Utilisateurs vers SRV-APP, TCP 8080	A	Besoin métier
7	Utilisateurs vers SRV-BDD, TCP 3306	R	Un poste ne doit pas interroger la base directement
8	Utilisateurs vers Internet, TCP 80/443	A	Navigation (idéalement via un proxy)
9	Utilisateurs vers Management	R	Protéger les interfaces d'administration

10	ADMIN_PC vers serveurs et DMZ, TCP 22/443	A	Administration depuis une source unique et connue
11	Guests vers Internet, TCP 80/443	A	Accès visiteurs
12	Guests vers réseaux internes	R	Isolation totale
13	Serveurs vers Internet	R	Ouvrir seulement ponctuellement pour les mises à jour, jamais en permanence
14	Serveurs vers SRV_LOG, port 514	A	Centralisation des journaux (TCP dans le lab)

4. Règles attendues

Pare-feu / interface	Règles (dans l'ordre)
FW-INT / USERS	1. Pass TCP USERS net vers SRV_APP:8080. 2. Pass TCP USERS net vers !RFC1918 ports 80, 443. 3. Block any, log.
FW-INT / GUESTS	1. Pass TCP GUESTS net vers !RFC1918 ports 80, 443. 2. Block any, log.
FW-INT / MGMT	1. Anti-lockout (implicite). 2. Pass TCP ADMIN_PC vers RFC1918, ports ADMIN_PORTS. 3. Pass ICMP ADMIN_PC vers any (diagnostic). 4. Block any, log.
FW-INT / SERVERS	1. Pass TCP SRV_BDD vers SRV_LOG:514 (TP7). 2. Block any, log.
FW-INT / DMZ_LINK	1. Pass TCP RP_DMZ vers SRV_APP:8080, log. 2. Block any, log.
FW-EXT / WAN	Seulement les deux règles associées aux redirections NAT : TCP 80 et 443 vers 172.16.50.10.
FW-EXT / DMZ	Pass TCP 80, 443 depuis 192.168.10.0/24 et 192.168.40.0/24 vers any. Le reste est bloqué.
FW-EXT / NAT sortant	Mode hybride : 192.168.0.0/16 vers WAN address ; route statique 192.168.0.0/16 via 172.16.50.2.

5. Réponses attendues aux questions

Question	Éléments de réponse
0.1	Un bridge VLAN aware filtre et étiquette les trames 802.1Q ; le VLAN Tag d'une carte la place en port d'accès de ce VLAN. Sans tag, la carte est un trunk qui reçoit tous les VLAN.
0.2	Reproductibilité, rapidité, cohérence des versions et du durcissement de base ; moins d'écarts de configuration, correctifs appliqués une fois sur le gabarit.
0.3	Les bridges isolés n'ont pas d'accès Internet ; les installations passent donc par vmbr0 (ou vmbr9) en phase de préparation.
1.1	Tous les services des serveurs (SSH, base, application, éventuellement port 80). Le SSH et la base n'ont pas de raison d'être joignables depuis un poste utilisateur.
1.2	Confidentialité (lecture de la table), Intégrité (écriture possible), Disponibilité (suppression, arrêt du service), Traçabilité (action non journalisée côté base).
1.3	Après une première intrusion, l'attaquant explore et rebondit de machine en machine ; en réseau plat rien ne l'arrête.
1.4	Segmentation en VLAN, filtrage inter-zones, moindre privilège, pare-feu local sur les serveurs, DMZ pour l'exposé.
2.1	Politique deny all et moindre privilège : on autorise explicitement ce qui est nécessaire, rien d'autre.
2.2	Entre DMZ et LAN, on route pour conserver les adresses réelles dans les journaux et les règles ; le NAT sortant est fait par FW-EXT, à la frontière avec Internet.
2.3	Elle évite de se couper l'accès à l'interface d'administration par une règle trop stricte ; ne pas la retirer sans solution de secours (console).
3.1	Aucune règle n'autorise ces flux : deny all. Le DHCP fonctionne car pfSense crée automatiquement les règles nécessaires au service DHCP activé sur l'interface.
3.2	Une ligne de blocage identifie interface, IP source, IP destination, port et action (Block), par la règle « Default deny ».
3.3	Non : le trafic inter-VLAN passe par le routeur (FW-INT) ; c'est ce qui permet de le filtrer.
3.4	Non : le VLAN sépare, c'est le filtrage entre VLAN qui protège.

4.1	Les trois premiers passent par le NAT et RP-DMZ ; le réseau interne n'est ni routé ni autorisé depuis le WAN. Deux barrières successives (FW-EXT puis FW-INT).
4.2	172.16.50.10 (RP-DMZ), car le proxy ouvre sa propre connexion ; X-Forwarded-For / X-Real-IP conservent l'adresse du client.
4.3	Un seul flux : 192.168.20.20:8080. Pour réduire : WAF, durcissement et isolement du reverse-proxy, IDS, supervision, règle limitée aux méthodes et chemins nécessaires.
4.4	Les utilisateurs qui tapent http:// sont redirigés vers HTTPS au lieu de recevoir une erreur ; on ne sert aucun contenu en clair.
5.1	Il n'a aucun besoin légitime de la base ; si un accès est requis, il passe par une couche applicative interne. Principe de moindre privilège.
5.2	Cela faciliterait l'exploitation de tout service vulnérable, l'attaque par force brute sur SSH ou la base, et la propagation latérale.
5.3	Block abandonne sans réponse (le scanneur voit « filtered » et ralentit) ; Reject renvoie un refus et révèle l'existence de l'hôte. Block est préférable côté Internet.
5.4	La première règle qui correspond s'applique ; placer un « block any » avant un « pass » rend le pass inopérant.
6.1	Lignes de blocage identifiant interface, IP source, IP destination, port et règle (« Default deny » ou règle de blocage explicite).
6.2	Réseau plat : tous les ports de service atteignables ; réseau segmenté : un seul port (8080) atteignable.
7.1	Deux fois : réseau (FW-INT) et hôte (ufw, côté base). Défense en profondeur.
7.2	Limite les dégâts si l'application ou le compte est compromis : pas d'écriture, pas d'usage depuis un autre poste.
7.3	L'événement est visible côté pare-feu et serveur ; les journaux restent disponibles même si le serveur est compromis ou effacé.

6. Erreurs fréquentes et pistes d'aide

Erreur observée	Piste pour l'étudiant

Passer un VLAN Tag sur la carte du pare-feu interne côté trunk	Rappeler que la carte de FW-INT doit rester sans tag pour recevoir tous les VLAN.
Oublier la route de RP-DMZ vers 192.168.0.0/16 via FW-INT	Faire tracer le chemin avec traceroute et regarder les journaux des deux pare-feu : le routage asymétrique en est la cause.
Réponses du trafic entrant par DMZ_LINK qui repartent via FW-EXT	Sur FW-INT, cocher « Disable reply-to on WAN rules » dans System > Advanced > Firewall & NAT.
Laisser « Block private networks » sur le WAN	Le trafic de KALI-EXT (adresses de laboratoire) est rejeté ; décocher les deux blocages sur les WAN de laboratoire.
Écrire les règles avant la matrice de flux	Refaire dans l'ordre : décider, écrire, tester, prouver.
Règle « pass any any » ajoutée « pour tester »	Exiger sa suppression ; une règle temporaire doit porter un commentaire et une date.
Verrouillage SSH après ufw ou sshd_config	Console Proxmox ; toujours tester dans un second terminal avant de fermer la session.
Résultats de nmap mal interprétés (filtered et closed confondus)	Reprendre le tableau d'interprétation du TP6.

7. Barème indicatif et attendus de niveau

Niveau	Description
Maîtrise	Architecture complète fonctionnelle, matrice et règles cohérentes, tests prouvés par journaux, justification argumentée (alternatives, limites).
Satisfaisant	Zones et VLAN en place, DMZ fonctionnelle, matrice correcte, quelques tests non prouvés ou règles trop larges.
Fragile	Segmentation partielle, règles permissives, tests non rattachés à la matrice, justification descriptive.
Insuffisant	Pare-feu non opérationnel, DMZ sans filtrage, absence de preuves.

Grille sur 20 points : voir l'annexe D de la page Travaux pratiques.

© 2026 **Twagirumukiza** — Support pédagogique BTS SIO 2 · Cybersécurité

Suivre Twagirumukiza sur LinkedIn ↗